Security Engineering – Lecture 3

28.10.2026 Bookkeeping/Banking, Threat Models Nur Folien; kein passendes Transkript.

1 Muss ich wissen

Auswahl nach den Fragenfolien auf PDF-S. 70–74; alle Seitenangaben beziehen sich auf das 77-seitige PDF.

Security Policy oder Security Model? S. 3–7

- Eine **Security Policy** beschreibt die Schutzziele knapp in natürlicher Sprache, während ein **Security Model** sie formal beschreibt.
- Die drei Fallstudien betrachten **Insider Threats**, etwa illoyale Beschäftigte oder Malware auf deren Geräten.
- Das **Basic Security Theorem** besagt, dass ein sicherer Anfangszustand und ausschließlich sichere Zustandsübergänge die Sicherheit aller erreichten Zustände gewährleisten.

Bell–LaPadula: Confidentiality S. 6–7

- **Security Levels** ordnen die Clearance eines Subjects S und die Classification eines Objects O mit den Bezeichnungen $L(S)$ und $L(O)$.
- **No read up**: Lesen verlangt $L(O) \leq L(S)$, sodass ein Subject keine höher klassifizierten Daten lesen darf.
- **No write down**: Schreiben verlangt $L(S) \leq L(O)$, sodass höher klassifizierte Informationen nicht nach unten gelangen.
- Die **Discretionary Security Property** verlangt zusätzlich passende Zugriffsrechte in einer Access Matrix.
- Das **Tranquillity Principle** hält die Classification eines Subjects oder Objects während seiner Referenzierung unverändert.

Biba: Integrity statt Confidentiality S. 19–20

- Das **Biba Model** schützt Integrity und verwendet gegenüber BLP die umgekehrte Flussrichtung.
- **No read down**: Lesen verlangt $L(O) \geq L(S)$, damit niedrigere Integrity keine höhere verunreinigt.
- **No write up**: Schreiben verlangt $L(S) \geq L(O)$, damit niedrigere Integrity keine höher eingestuften Daten verändert.
- **Datenfluss** ist im gezeigten Modell nur von hoher zu niedriger Integrity erlaubt, etwa zwischen Safety-, Monitoring- und Enterprise-Ebene.

Multilateral Security: seitlich abschotten S. 11–18

- **Vertical Access Control** trennt hierarchische Stufen, während **lateral** Informationsflüsse zwischen Bereichen derselben Clearance begrenzt.
- Das **Lattice Model** ergänzt Compartments und Labels, wobei BLP nur eine partielle Ordnung statt einer einzigen linearen Rangfolge benötigt.
- Das **Chinese Wall Model** trennt konkurrierende Kunden oder Organisationseinheiten, um Interessenkonflikte zu verhindern.
- **Delegation** überträgt Befugnisse unter Einschränkungen und Verantwortlichkeit, etwa als zeitlich begrenzten Zugriff auf Patientendaten.
- Ein **Honeypot** lockt Angreifer oder regelwidrig handelnde Insider zu einem überwachten Ködersystem, etwa einer falschen Prominentenakte.

Clark–Wilson: kontrollierte Datenänderungen S. 25–27

- **Constrained Data Items (CDI)** sind integritätsgeschützte Daten wie Kontostände, während **Unconstrained Data Items (UDI)** nicht diesen Integritätsauflagen unterliegen.
- Eine **Transformation Procedure (TP)** verändert CDI ausschließlich so, dass deren Integrity erhalten bleibt.
- Eine **Integrity Validation Procedure (IVP)** prüft, ob die CDI die Integritätsbedingungen erfüllen.
- Erlaubte **Triples (Subject, TP, CDI)** begrenzen, wer welche Prozedur auf welche Daten anwenden darf, und unterstützen Separation of Duty.
- Weitere Regeln verlangen **Authentication**, rekonstruierbare Änderungen im **Audit Trail**, kontrollierte UDI-zu-CDI-Überführung und besondere Subjects zum Ändern der Triples.

Bookkeeping und Separation of Duty S. 22, 25–28

- **Double-entry Bookkeeping** ordnet jeder Buchung eine entgegengesetzte Buchung zu, damit sich die Bücher auf Konsistenz prüfen lassen.
- Im **Clark–Wilson-Beispiel** erhöht eine TP einen Kontostand um denselben Betrag, um den sie einen anderen senkt.
- **Separation of Duty** verhindert, dass eine einzelne Person einen kritischen Prozess vollständig kontrolliert.
- **Serial** trennt aufeinanderfolgende Arbeit und Kontrolle, während **parallel** mehrere Freigaben vor einer großen irreversiblen Aktion verlangt.

Agency Problem und Internal Controls S. 30–33

- Das **Agency Problem** entsteht, weil Beschäftigte ihren eigenen Nutzen statt zwingend den des Arbeitgebers maximieren.
- **Internal Controls** müssen neben Fraud auch Nepotism und Empire-building berücksichtigen und Anreize sowie Sanktionen einbeziehen.
- **Balancing Books** allein genügt nicht, weil formal passende Bücher beispielsweise erfundene Geschäftspartner nicht ausschließen.
- **Threat Modelling** soll Beschäftigte direkt einbeziehen, weil sie organisatorische Schwachstellen kennen.

OCTAVE: kritische Assets zuerst S. 38

- **OCTAVE** steht für **Operationally Critical Threat, Asset, and Vulnerability Evaluation** und fokussiert die wichtigsten Assets einer Organisation.
- **Organizational View** erfasst Assets, Threats, Schutzlücken und Risiken; **Technological View** untersucht Schwachstellen der Infrastruktur.
- **Strategy and Plan Development** priorisiert verbleibende Risiken und plant deren langfristige Behandlung.

PASTA: sieben Stufen in fester Reihenfolge S. 39

- **PASTA** steht für **Process for Attack Simulation & Threat Analysis**.
- Zuerst kommen **1 Define the Objectives**, **2 Define the Technical Scope** und **3 Decompose the Application**.
- Danach folgen **4 Analyze the Threats**, **5 Vulnerability Analysis** und **6 Attack Analysis**.
- Den Abschluss bildet **7 Risk and Impact Analysis**, wobei Standardmethoden an die Organisation angepasst werden sollen.

System Model und Data Flow Diagram S. 41–47

- Ein **System Model** beantwortet, was gebaut wird, und erfasst Stakeholders, Assets und Prozesse als Grundlage der Threat-Analyse.
- **BPML**-Diagramme zeigen Business Workflows, während **UML Use Case Diagrams** Actors, Use Cases, Systemgrenzen und Beziehungen darstellen.
- Ein **DFD** enthält External Entities als Rechtecke, Processes als Kreise oder abgerundete Rechtecke, Data Stores als parallele Linien oder offene Rechtecke sowie Data Flows als Verbindungspfeile.
- Ein **Logical DFD** beschreibt benötigte Datenflüsse ohne Implementierungsdetails, während ein **Physical DFD** Software, Hardware und Dateien einbezieht.
- **Trust Boundaries** markieren Grenzen zwischen Zonen mit unterschiedlichem Vertrauen.

DFD Levels: vom Kontext zu Details S. 46

- **Level 0** zeigt das ganze System als einen Prozess im Context Diagram.
- **Level 1** zerlegt diesen Prozess in Teilprozesse und zeigt detailliertere Datenwege.
- **Level 2** ergänzt weitere Teilprozesse, Interaktionen und Data Stores; **Level 3** dient sehr komplexen Systemen und ist eher unüblich.

STRIDE: Security Threats systematisch prüfen S. 50–51

- **STRIDE** bedeutet **Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege**.
- Die Folien nennen als Ziele **Confidentiality, Integrity, Availability** sowie **Authenticity** bei Einbezug der Trust Boundaries.
- Die **DFD-Zuordnung** prüft bei Entities S/R, bei Data Flows T/I/D, bei Data Stores T/R/I/D und bei Processes alle sechs Kategorien.
- **STRIDE** wird bereits im Design und wiederholt eingesetzt; die Ergebnisse können mit **DREAD** zur Risikobewertung verbunden werden.

LINDDUN: Privacy Threats statt nur CIA S. 52–53

- **Linking** verknüpft Daten oder Handlungen, während **Identifying** die Identität einer Person durch Leaks oder Schlussfolgerungen erschließt.
- **Non-repudiation** ermöglicht die Zuordnung einer Aussage zu einer Person und wird hier als Privacy Threat betrachtet.
- **Detecting** erschließt die Beteiligung einer Person durch Beobachtung, während **Data Disclosure** übermäßiges Sammeln, Speichern, Verarbeiten oder Teilen persönlicher Daten umfasst.
- **Unawareness / Unintervenability** bedeutet ungenügende Information, Beteiligung oder Eingriffsmöglichkeiten für betroffene Personen.
- **Non-compliance** bedeutet Abweichen von einschlägigen Best Practices, Standards oder Rechtsvorgaben; die Kategorien werden auf DFD-Elemente angewendet.

Top-down oder Bottom-up? S. 49, 61

- **Top-down** beginnt beim unerwünschten Ergebnis und verfolgt mögliche Ursachen zurück, etwa mit Attack Trees, STRIDE oder LINDDUN.
- **Bottom-up** beginnt bei Möglichkeiten einzelner Beteiligter oder Angreifer und verfolgt die erreichbare Kompromittierung, etwa mit Kill Chains, Attack Graphs oder Szenarien.
- **Stakeholders, diverse Teams, Fachleute und frühere Vorfälle** liefern konkrete Angriffsmöglichkeiten statt bloßer Vermutungen.

Attack Trees: Bedingungen für ein Angriffsziel S. 58–60

- Die **Root** ist das Angriffsziel, das von oben nach unten in Teilziele und Bedingungen zerlegt wird.
- Ein **OR**-Knoten ist erfüllt, wenn eine seiner Alternativen erfüllt ist; ein **AND**-Knoten verlangt die gemeinsam notwendigen Bedingungen.
- Die **Auswertung** läuft von den erfüllten Kindknoten zu ihrem direkten Elternknoten bis zur Root.

Attack Graphs: Angriffspfade verbinden S. 62–63

- Ein **Attack Graph** stellt mögliche Angriffspfade bis zu einer erfolgreichen Kompromittierung dar.
- Im **Exploit-oriented Graph** sind Knoten Netzwerkzustände und Kanten Exploits, die zum nächsten kompromittierten Zustand führen.
- Im **Condition-oriented Graph** sind Knoten Vor- oder Nachbedingungen von Exploits und Kanten ihre ermöglichenden Beziehungen.
- Im **Asset/Host-oriented Graph** sind Knoten Hosts oder Assets und Kanten mögliche Exploits oder Eintrittspfade zwischen ihnen.
- **Abgrenzung**: Der Tree zerlegt Zielbedingungen, während der Graph Zustands-, Bedingungs- oder Hostverbindungen eines Angriffs zeigt.

MITRE ATT&CK: konkrete Angreiferhandlungen S. 54–55

- **MITRE ATT&CK** ist eine Wissensbasis realer Angreiferhandlungen, die konkrete Szenarien für ein Threat Model liefert.
- **Tactics** beschreiben das Warum beziehungsweise das taktische Ziel, während **Techniques** das Wie beschreiben.
- **Sub-techniques** präzisieren eine Technique; **Procedures** sind deren konkrete Implementierung oder beobachtete Anwendung.
- **ATT&CK Navigator** hilft beim Erkunden und Annotieren der Matrizen, während **MITRE ATLAS** AI-bezogene Angreiferhandlungen behandelt.

OWASP Top 10: priorisierte Application Risks S. 56–57

- Die ursprünglichen **OWASP Top 10** fokussieren wichtige Risiken von Web Applications; daneben gibt es spezialisierte Listen für andere Anwendungen.
- Die Folien beschreiben als **Datengrundlage** NVD-Einträge mit CVEs, die nach CWEs kategorisiert werden.
- Die **Rangbildung laut Folien** berücksichtigt Exploitability, die durchschnittliche Wahrscheinlichkeit fehlender Schutzmaßnahmen und technische Auswirkungen.
- **Zusammenspiel**: STRIDE oder LINDDUN strukturieren Threat-Kategorien, während ATT&CK und OWASP konkrete Angriffsszenarien beziehungsweise Risikoklassen beisteuern.

2 Hinweise der Lehrperson

Nur Angaben aus den aktuellen Folien; mündliche Hinweise vom 28.10. sind ohne Transkript nicht überprüfbar.

Minitest: Form und Lernfokus laut Folien S. 69–75

- **Fragenfolien** sind der Lernfokus, insbesondere Definitionen, aber das ganze Skript soll gelernt werden.
- **Moodle Quiz**: Genannt werden fünf Minuten zu Vorlesungsbeginn und zwei bis drei Fragen mit True/False, Multiple Choice, Fill in Text oder Mathematical Computations.
- **Wertung**: Vorgesehen sind zwölf Tests zu je fünf Punkten, von denen die neun besten mit maximal 45 Punkten zählen.
- **Datumswarnung**: Die Fragen-Trennfolie nennt den 24. Oktober für den ersten Minitest, was für diese am 28.10. eingeordnete Lecture kein bestätigter kommender Termin ist.

Projekt: jetzt System und Bedrohungen festlegen S. 67–68

- **Startaufgaben** sind System und Mission definieren, eine kurze Security Policy formulieren sowie Threat Actors mit Why und How bestimmen.
- **Methodenwahl** soll sowohl das System Modelling als auch die Threat Identification abdecken; Fragen können in Moodle gestellt werden.
- **Write-up**: Die verlinkte Vorlage ist zu verwenden; Zweierteams schreiben entweder zwei getrennte Berichte zu unterschiedlichen Teilthemen mit jeweils acht Seiten oder einen gemeinsamen Bericht mit gekennzeichneten Abschnittsbeiträgen.

3 Gut zu wissen

Medical Records: Berechtigung ist nicht gleich Bedarf S. 14–15

- Die **UK/Scotland-Fallstudie** beschreibt zu weitreichende Zugriffe für Receptionists, die zur Identitätsprüfung auch vertrauliche Akteninhalte lesen konnten.
- **Anonymization** ist schwierig, weil öffentliche und private Informationen in medizinischen Daten miteinander verknüpft sind.
- **OpenSAFELY** wird als positives Beispiel genannt, bei dem Researchers Patientendaten nicht herunterladen und die Verarbeitung in der Cloud verbleibt.

Weitere Schutzideen und ihre Grenzen S. 8–9, 32

- Eine **Data Diode** erlaubt Datenfluss physisch nur in eine Richtung und wird als spezialisierte Hardware mit minimaler Covert-Channel-Leakage vorgestellt.
- **Composability** ist nicht garantiert, denn sichere Einzelkomponenten ergeben nicht automatisch ein sicheres Gesamtsystem.
- **Fraud Mitigation** unterscheidet Deter als Abschrecken, Prevent als Blockieren, Detect als Erkennen, Alarm als Warnen und Delay als Zeitgewinn für Eingriffe.

Threat Modelling Manifesto: gemeinsam und anwendbar S. 64–65

- **Do**: systematisch vorgehen, informierte Kreativität nutzen, verschiedene Perspektiven einbeziehen, hilfreiche Tools einsetzen und Theorie praktisch anwenden.
- **Don't**: auf einen einzelnen Hero Threat Modeler setzen, beim Bewundern des Problems stehen bleiben, Details überfokussieren oder auf die eine perfekte Darstellung warten.

4 Selbsttest

Zehn Kurzfragen nach den Themen der Fragenfolien, PDF-S. 70–74.

1. Welche Regeln unterscheiden BLP und Biba?

Antwort: BLP schützt Confidentiality mit No read up / No write down; Biba schützt Integrity mit No read down / No write up.

2. Was leisten laterale Modelle und die Chinese Wall?

Antwort: Sie begrenzen Informationsfluss zwischen Bereichen statt nur zwischen Hierarchiestufen; die Chinese Wall trennt insbesondere konkurrierende Kunden und Interessenkonflikte.

3. Was sind CDI, UDI, TP und IVP in Clark–Wilson?

Antwort: CDI sind integritätsgeschützte Daten, UDI unterliegen diesen Auflagen nicht, TP ändern CDI integritätserhaltend und IVP prüfen deren Integrity.

4. Was ist das Agency Problem, und welche Duty-Trennung gibt es?

Antwort: Beschäftigte verfolgen eigenen Nutzen; Serial trennt Arbeit und nachfolgende Kontrolle, Parallel verlangt mehrere Freigaben vor der Aktion.

5. Wofür steht OCTAVE, und welche drei Phasen hat es?

Antwort: Operationally Critical Threat, Asset, and Vulnerability Evaluation: Organizational View, Technological View, Strategy and Plan Development.

6. Wofür steht PASTA, und wie lautet seine Reihenfolge?

Antwort: Process for Attack Simulation & Threat Analysis: Objectives, Technical Scope, Application Decomposition, Threat Analysis, Vulnerability Analysis, Attack Analysis, Risk and Impact Analysis.

7. Welche Elemente und Detailstufen hat ein DFD?

Antwort: External Entities, Processes, Data Stores und Data Flows; Level 0 zeigt das System als einen Prozess, Level 1–3 zerlegen es zunehmend detailliert.

8. Was bedeuten STRIDE und LINDDUN?

Antwort: STRIDE: Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege; LINDDUN: Linking, Identifying, Non-repudiation, Detecting, Data Disclosure, Unawareness/Unintervenability, Non-compliance.

9. Wie unterscheiden sich Top-down, Bottom-up, Tree und Graph?

Antwort: Top-down zerlegt das unerwünschte Ziel, Bottom-up verfolgt Angriffsmöglichkeiten; ein Tree beschreibt Zielbedingungen mit AND/OR, ein Graph verbindet Zustände, Bedingungen oder Hosts über Angriffspfade.

10. Was liefern ATT&CK und OWASP für ein Threat Model?

Antwort: ATT&CK liefert Angreiferverhalten mit Tactics als Warum, Techniques als Wie, Sub-techniques als Präzisierung und Procedures als konkrete Umsetzung; OWASP liefert priorisierte Application-Risikoklassen.